Hao → Jerry｜部署與協作交接

lionclub 會員 App · 2026/10/12 · 審閱版

目前狀態	程式已在本機分支完成並通過正式 build；依 Hao 指示，尚未推送 main。

一、Hao 已完成的程式

- 好友個人頁：/members/[id]；好友清單與首頁可導覽，API 僅允許本人或 ACCEPTED 好友，非好友回 403。
- 會員資歷：GET / POST /api/me/experiences；PATCH / DELETE /api/me/experiences/[experienceId]；好友看不到 only_me。
- 活動通知：指定好友與整個分會；後端驗證好友關係，整會通知限活動建立者或授權幹部。
- 活動管理：建立者 / 授權幹部可編輯與刪除；顯示報名數，capacity 滿額回 409。
- 幹部權限：/admin/roles；會長 / 區級角色可授予與撤銷 CLUB_OFFICER、CLUB_FINANCE。
- 大頭貼：前端預覽、格式與 5 MB 驗證、presigned PUT、photoUrl 寫回流程。
- 忘記密碼：申請 / 重設頁、30 分鐘一次性 token、bcrypt 更新、SES 寄信流程。

分支：codex/friend-profile-and-handoff ｜ 目前基底：origin/main f3a885d

二、Jerry 部署前必做

A. 資料庫 migration

• 先備份 / 確認正式 RDS，再執行 prisma/migrations/20261012150000_add_password_reset_token/migration.sql。

• migration 新增 PasswordResetToken；程式部署與 migration 順序需協調，避免忘記密碼 API 在舊 schema 上執行。

B. S3 / CloudFront（大頭貼）

• 建立專用 bucket；允許前端網域對 PUT 執行 CORS，只接受 JPG / PNG / WebP。

• Amplify compute role 授予 s3:PutObject，resource 建議限制為 bucket 的 avatars/*。

• 設定 AWS_REGION、AVATAR_BUCKET_NAME、AVATAR_PUBLIC_BASE_URL；公開讀取建議由 CloudFront 提供。

C. SES（忘記密碼）

• 驗證 PASSWORD_RESET_FROM_EMAIL；若 SES 仍在 sandbox，申請 production access 或先驗證測試收件人。

• Amplify compute role 授予 ses:SendEmail；確認 NEXT_PUBLIC_APP_URL 為正式 HTTPS 網址。

D. 角色與正式環境

• 以具 CLUB_PRESIDENT / 區級權限帳號進入 /admin/roles，指派實際幹部；職稱不會自動給系統權限。

• 確認 Secrets Manager 的 DATABASE_URL / AUTH_SECRET 保持正確，且不把密鑰放入 Git。

環境變數	用途
AWS_REGION	S3 與 SES 區域；預設 ap-northeast-1。
AVATAR_BUCKET_NAME	大頭貼上傳 bucket。
AVATAR_PUBLIC_BASE_URL	CloudFront 或可公開讀取的基底網址。
PASSWORD_RESET_FROM_EMAIL	SES 已驗證寄件地址。
NEXT_PUBLIC_APP_URL	QR 與密碼重設連結的正式網站來源。

三、API 與權限契約

路由	權限 / 行為
GET /api/members/[memberId]	本人或 ACCEPTED 好友；非好友 403；好友不回傳 only_me 資歷。
/api/me/experiences	只操作自己的資歷；新增 / 修改後 under_review；verified 禁止會員直接改刪。
POST /api/me/avatar-upload	登入會員；JPG / PNG / WebP、≤5 MB；回傳 5 分鐘 presigned PUT URL。
POST /api/notifications	selected 僅允許已接受好友；organization 限活動建立者或涵蓋分會的管理角色。
PATCH / DELETE /api/events/[id]	活動建立者或涵蓋主辦組織的幹部；名額不得低於現有報名數。
POST /api/events/[id]/register	已報名則取消；未報名且達 capacity 時回 409。
/api/admin/roles	會長 / 區級以上管理；目前只可授予或撤銷分會幹部、財務。
/api/auth/forgot-password	回覆不揭露帳號存在與否；已註冊者寄出 30 分鐘連結。
/api/auth/reset-password	token 只存 SHA-256 hash；成功後更新 bcrypt 密碼並失效 token。

未完成邊界

- 通知的『自訂群組』尚無資料模型；目前完成指定好友與整個分會。
- 資歷 organizationId 的官方組織自動對應尚待補強；目前保留 organizationName 與待核標記。
- 好友推薦排序 / 篩選（原項目 4）與 unit / API / e2e（原項目 9）仍由 Jerry 後續處理。

四、共同驗收清單

情境	預期結果
好友頁	Tom / Hao / Jerry 建立並接受好友後可互看；未成為好友直接呼叫 API 回 403。
資歷	新增 / 修改 / 刪除後重新整理仍存在；好友看不到 only_me；verified 改刪回 409。
活動容量	有限名額活動報滿後下一位回 409；管理者不可把 capacity 調低於已報名數。
通知	指定好友不可混入非好友；整會通知需活動建立者或授權幹部。
大頭貼	三種格式可上傳；其他格式或 >5 MB 被拒；好友頁可讀到新圖。
忘記密碼	不存在信箱不洩漏；連結 30 分鐘到期、使用一次即失效，新密碼可登入。
幹部權限	會長可授予 / 撤銷；一般會員 403；不可在此撤銷自己的管理權限。

五、風險與驗證紀錄

- 高優先：RDS 5432 不應長期開放 0.0.0.0/0；請收斂至 VPC / 安全群組。
- 本機與正式環境目前共用資料庫；請建立獨立測試 DB，避免驗收改到正式會員資料。
- Prisma 維持 6.19.3，不在本次工作升級 major version。
- 已通過 Prisma Client generate、TypeScript tsc --noEmit 與 Next.js production build（34 routes）。
- 本輪未執行正式 RDS migration，未呼叫正式 S3 / SES，也未推送 main。

> 推送規則：Hao 看過此版本並明確同意後，才可將審閱內容推送 main。